

Security+ 2.4 · Application Attacks

Mestre CyberSec — PDF baseado na aula do Professor Messer · 2.4 — Application Attacks (11:48) · [vídeo original](#) · [YouTube](#)

Aplicação = a superfície mais atacada: privilege escalation (horizontal = mesmo nível, outro dado; vertical = tier acima — user vira admin); directory traversal (../etc/passwd); remote code execution. Defesa: input validation, patching, WAF, SCA (library vulnerable), secure coding.

Highlights que a prova cobra

- Privesc horizontal (mesmo nível, outro dado) vs vertical (tier acima)
- Directory traversal: sobe com ../ pra /etc/passwd
- Defesa: input validation SEMPRE; nunca confie no input

Dicas de prova

- 'user gains higher-level access' = privilege escalation (vertical)
- 'path traversal reads arbitrary files' = directory traversal

Cenário clássico: Cenário: 'usuário comum acessa a conta de outro usuário' = privesc horizontal; 'usuário vira admin' = vertical.

Perguntas de treino (10 questões)

Gabarito no fim. Tenta responder SEM olhar.

1. Atacante entra como usuário comum e vira 'Domain Admin'. Esse ganho de poder é:
A) Escalada de privilégio (privilege escalation)
B) Negação de serviço
C) Engenharia social
D) Sniffing

2. Injeção de comando SQL num campo de login explora principalmente a falta de:

- A)** Criptografia do disco
- B)** Validação de entrada (input)
- C)** Backup
- D)** Antivírus

3. Cenário corporativo (Application Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'Privesc horizontal (mesmo nível, outro dado) vs vertical (tier acima)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Privesc horizontal (mesmo nível, outro dado) vs vertical (tier acima)...

4. Cenário corporativo (Application Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'Directory traversal: sobe com ../ pra /etc/passwd'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Directory traversal: sobe com ../ pra /etc/passwd...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

5. Cenário corporativo (Application Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'Defesa: input validation SEMPRE; nunca confie no input'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Defesa: input validation SEMPRE; nunca confie no input...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

6. Cenário corporativo (Application Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'user gains higher-level access' = privilege escalation (vertical). Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'user gains higher-level access' = privilege escalation (vertical)...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (Application Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'path traversal reads arbitrary files' = directory traversal. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'path traversal reads arbitrary files' = directory traversal...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

8. Cenário corporativo (Application Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'Cenário: 'usuário comum acessa a conta de outro usuário' = privilege horizontal; 'usuário vira admin' = vertical.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Cenário: 'usuário comum acessa a conta de outro usuário' = privilege horizontal...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Application Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'Privesc horizontal (mesmo nível, outro dado) vs vertical (tier acima)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Privesc horizontal (mesmo nível, outro dado) vs vertical (tier acima)...

10. Cenário corporativo (Application Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'Directory traversal: sobe com ../ pra /etc/passwd'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Directory traversal: sobe com ../ pra /etc/passwd...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO

- 1) A — Escalada de privilégio (privilege escalation).** Privilege escalation = subir de acesso baixo pra administrador. Virar Domain Admin dá controle do domínio inteiro (todas as máquinas e contas). É o passo 2 da cadeia.
- 2) B — Validação de entrada (input).** SQL injection acontece quando a aplicação NÃO valida/sanitiza o que o usuário digita e joga direto no banco. Validação de entrada é a defesa.
- 3) D — Implementar a solução correspondente: Privesc horizontal (mesmo nível, outro dado).** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Application Attacks): Privesc horizontal (mesmo nível, outro dado) vs vertical (tier acima). As demais alternativas configuram violação
- 4) C — Implementar a solução correspondente: Directory traversal: sobe com ../ pra /etc.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Application Attacks): Directory traversal: sobe com ../ pra /etc/passwd. As demais alternativas configuram violações graves de conformi
- 5) A — Implementar a solução correspondente: Defesa: input validation SEMPRE; nunca con.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Application Attacks): Defesa: input validation SEMPRE; nunca confie no input. As demais alternativas configuram violações graves de con
- 6) B — Implementar a solução correspondente: 'user gains higher-level access' = privile.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Application Attacks): 'user gains higher-level access' = privilege escalation (vertical). As demais alternativas configuram violações g
- 7) A — Implementar a solução correspondente: 'path traversal reads arbitrary files' = d.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Application Attacks): 'path traversal reads arbitrary files' = directory traversal. As demais alternativas configuram violações graves
- 8) B — Implementar a solução correspondente: Cenário: 'usuário comum acessa a conta de .** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Application Attacks): Cenário: 'usuário comum acessa a conta de outro usuário' = privesc horizontal; 'usuário vira admin' = vertical..
- 9) D — Implementar a solução correspondente: Privesc horizontal (mesmo nível, outro dado).** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Application Attacks): Privesc horizontal (mesmo nível, outro dado) vs vertical (tier acima). As demais alternativas configuram violação
- 10) C — Implementar a solução correspondente: Directory traversal: sobe com ../ pra /etc.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Application Attacks): Directory traversal: sobe com ../ pra /etc/passwd. As demais alternativas configuram violações graves de conformi

